

Rahasya — Product Requirements Document

Sep 21, 2026 · @Kumar

1. Overview

Rahasya (रहस्य, Hindi for "secret") is a zero-knowledge personal password manager delivered as one Expo (React Native + React Native Web) codebase that ships an Android APK and a web app, backed by a NestJS API and PostgreSQL. It is a portfolio project, so production-grade security and code quality matter more than feature count.

Problem. People reuse weak passwords because strong, unique ones are hard to remember and manage across devices. Commercial managers solve this but are black boxes; Rahasya demonstrates how a secure one is built end to end.

Goals

- Encrypt credentials on the client so the server cannot read them, unless a deployment turns on server escrow mode (FR-30), which is disclosed to users.
- Make saving, finding and copying a password take under 5 seconds on phone and web.
- Organise entries with nested groups, labels and multiple credentials per entry.
- Showcase senior-level engineering: monorepo, shared code, tests, CI, threat model.

Non-goals (v1)

- Sharing vaults between users or organisations.
- iOS build and browser extension.
- Enterprise features (SSO, and policy enforcement beyond auto-lock and two-step sign-in).

2. Target users

The primary user is a single technically capable individual; the secondary audience is a reviewer (recruiter or hiring engineer) evaluating the project.

Persona	Context	Needs	Pain today
Priya, power user (primary)	150+ accounts, Android phone + laptop	Fast search, groups, labels, autofill, TOTP codes	Passwords scattered across browser, notes app and memory

Persona	Context	Needs	Pain today
Arun, cautious user	Banking and work accounts	Strong encryption, biometric unlock, re-auth before reveal	Distrusts cloud storage of secrets
Reviewer	Opens repo and live demo for 10 minutes	Demo account, clear README, threat model, tests	Most portfolio apps are CRUD demos with no security depth

3. Scope

The MVP delivers a secure, synced vault with show/hide, groups, labels and add/edit on both platforms; everything else is phased.

Phase	Features
Public beta (v1)	Register/login with master password, client-side encryption, vault CRUD, show/hide password, groups (nested), labels, custom fields, multiple credentials per entry, password generator, strength meter, search and filter, sync, auto-lock, clipboard auto-clear, three themes with Auto, Light and Dark; fingerprint and passkey unlock, TOTP codes, security health, password history, account two-step sign-in, Trash with undo, desktop web layout, the 13 approved animations; admin console with admins and roles (Option A), emergency recovery (Option B) and escrow with urgent decrypt (Option C)
Phase 2	Offline cache with conflict handling, HIBP breach check, import (Chrome, Bitwarden, CSV), encrypted export (the rest of the original Phase 2 moved into the public beta)
Stretch	Android Autofill Service, share-sheet quick add, dark-web style breach alerts, self-hosted Docker deployment guide
Out of scope	Vault sharing, iOS, browser extension, SSO

4. Functional requirements

P0 = MVP, P1 = Phase 2, P2 = Stretch. Every requirement applies to both web and Android unless marked.

ID	Requirement	Acceptance criteria	Priority
FR-01	Account registration	Email + master password (min 12 chars, strength $\geq 3/4$); master password never sent to server; recovery kit PDF offered	P0
FR-02	Login and unlock	Derive key locally, fetch encrypted vault, decrypt in under 1.5 s on a mid-range phone; after 5 wrong master passwords, a 30-second wait before the next try	P0
FR-03	Show/hide password	Masked by default; eye toggle reveals; auto re-hides after 20 s or on blur/background	P0
FR-04	Copy without reveal (beside eye)	Copy icon sits directly beside the eye icon on every secret field (password, PIN, hidden custom fields, TOTP); one tap copies the real value while the field stays masked; toast "Copied, clears in 30 s"; clipboard cleared after 30 s; on Android 13+ the clip is flagged sensitive so the system clipboard preview stays hidden	P0
FR-05	Re-auth before reveal	Per-group setting; reveal requires biometric (Android) or master password (web)	P1
FR-06	Groups	Create, rename, delete, nest up to 3 levels; move one or many entries; entry belongs to exactly one group (default "Unsorted")	P0
FR-07	Labels	Add any number of labels per entry; autocomplete existing labels; filter by one or more labels (AND/OR)	P0
FR-08	Multiple credentials per entry	One entry holds extra secret fields (e.g. login password, transaction PIN, security answer), each with its own label, type and show/hide	P0

ID	Requirement	Acceptance criteria	Priority
FR-09	Custom fields	Field types: Text, Secret, PIN, Link, Email, 2FA code, Note and Date (see FR-34); hidden types copy without showing; reorderable by drag handle; each field has a user-defined label	P0
FR-10	Add entry	Templates: Login, Bank, Card, Wi-Fi, Secure Note; required field = name only; save in 2 taps from template	P0
FR-11	Password generator	Length 8-128, toggles for upper/lower/digits/symbols, exclude ambiguous chars, passphrase mode (4-8 words)	P0
FR-12	Strength and reuse warning	Live strength meter while typing; warning if the password is already used in another entry	P0
FR-13	Duplicate detection	Warn when URL + username match an existing entry; offer "open existing"	P1
FR-14	Search and filter	Instant search across name, username, URL, labels, field labels; filter by group, label, type, favourite	P0
FR-15	Favourites and recents	Star entries; "Recently used" list of last 10	P0
FR-16	Sync	Changes appear on the other device within 5 s when online; the newest revision wins and the older version is kept in history (FR-22); pull down to sync on Android, sync button on web; updated items are briefly highlighted	P0
FR-17	Auto-lock	Lock after 5 min inactivity (configurable 1-60 min), on app background (Android) and when the browser tab is hidden (web)	P0
FR-18	Biometric and passkey unlock	Android fingerprint or face unlocks via a Keystore-wrapped key; on web a passkey (Windows Hello, Touch ID or a security key) unlocks via WebAuthn; both fall back to the master password	P1

ID	Requirement	Acceptance criteria	Priority
FR-19	TOTP codes	Store TOTP secret as a field; show live 6-digit code with countdown	P1
FR-20	Security dashboard	Overall score out of 100; counts and lists of weak, reused, old (> 1 year) and breached passwords; a "Fix these first" list	P1
FR-21	Import / export	Import Chrome and Bitwarden CSV/JSON; export encrypted JSON; plaintext export behind re-auth + warning	P1
FR-22	Password history	Keep last 10 previous values per secret field with dates	P1
FR-23	Android autofill	Suggest matching entries in other apps and Chrome on Android	P2
FR-24	Themes and light or dark mode	Three themes (Glass wallet D9, Daylight glass D10, Holographic D14) and three modes: Auto (default; D10 by day, D9 or D14 at night by the user's choice), Light and Dark; switch in Settings with a circular reveal from the tapped swatch; applies instantly without reload or re-unlock; remembered per device; Auto follows the OS live; no flash on web load; every screen passes 4.5:1 contrast in all three themes	P0
FR-25	Admin login	Separate /admin area with its own login; hardware security key (WebAuthn) mandatory; IP allowlist; 15-min session; the super admin is created with a server command at setup (FR-40); after that only the super admin or an Owner can add admins and assign roles in the console (FR-39), never through signup; built-in roles Super admin, Owner, Admin and Auditor (read-only) plus custom roles; the admin console has its own fixed light theme and works on phone and desktop browsers	P1

ID	Requirement	Acceptance criteria	Priority
FR-26	Account management (Option A)	Disable/enable account, force logout on all devices, reset 2FA after identity check, wipe vault; invite, lock and suspend accounts; without escrow, admin sees metadata only (entry count, devices, last login, two-step sign-in and recovery status)	P1
FR-27	Admin audit log	Every admin action stored append-only with admin, target user, reason, time and IP; the user is emailed about any action on their account; entries are hash-chained so tampering is detectable (shown as "Log chain verified"); filters for sign-ins, admin actions and emergency access; export	P1
FR-28	Emergency recovery opt-in (Option B)	User turns it on in Settings; the app seals a copy of the vault key to the recovery public key; turning it off deletes that copy	P1
FR-29	Emergency recovery request (Option B)	Admin files a request with a reason; user is notified at once; 48 h waiting period (configurable 0–7 days) during which the user can deny; the admin confirms the request with their security key or passkey (on web or phone), which starts the wait; one admin is enough; afterwards an admin with the recovery permission decrypts in the offline admin tool with the offline private key	P1
FR-30	Server escrow mode (Option C)	Deployment flag ESCROW_MODE; when on, every vault key is also sealed to a server escrow key protected by cloud KMS; signup and Settings show a plain-language disclosure; existing users are enrolled on their next unlock	P1

ID	Requirement	Acceptance criteria	Priority
FR-31	Urgent decrypt (Option C)	Admin picks one user or all users, enters a reason and confirms with the hardware key; records open in a read-only admin viewer, masked by default with show/hide and copy; export only as an encrypted file; all-users decrypt also asks the admin to type the organisation name to confirm; rate-limited; affected users notified	P1
FR-32	Group side navigation	Side navigation (slide-in drawer from a menu button on Android, always-visible sidebar on desktop web) lists All items, Favourites, every group with nested subgroups and item counts, Unsorted (always last) and labels; tapping one filters the vault list; groups appear only here, never on the home screen	P0
FR-33	Sort groups and entries	Sort by Name (A to Z, or Z to A) or Date created (newest or oldest first); set from a Sort button on the vault list page (not in the side navigation); the same order applies to entries in the list and groups in the side navigation; subgroups sort within their parent; when sorted by date, each group shows its creation date; choice remembered per device	P0
FR-34	Edit entry: add, remove and change fields	Tap a value to edit (marked "Edited"); minus button marks a field "Will be removed" with Undo until Save; Name, Username and Password are required and cannot be removed; "Add field" sheet offers 8 types (Text, Secret, PIN, Link, Email, 2FA code, Note, Date) plus suggestions for the entry type; new fields show a dashed outline and "New" tag; header counts unsaved changes; Save with no changes shows "Nothing to save yet"; removed values stay in history for 30 days; drag handle reorders fields	P0

ID	Requirement	Acceptance criteria	Priority
FR-35	Trash and undo delete	Swipe (Android) or the row's hover button (web) reveals Delete; the entry moves to Trash with an Undo toast for 5 s; Trash keeps entries 30 days, then deletes them for good; entries can be restored from Trash	P0
FR-36	Desktop web layout and shortcuts	Three panes on wide screens (sidebar, list, detail); the sidebar collapses to icons below 1200 px and the phone layout is used below 900 px; edit, add field (popover), generator, health and settings open in place; shortcuts: Ctrl K search, arrow keys to move, Enter to open, C to copy the password, E to edit	P0
FR-37	Admin console on phone	Sign-in, users, audit log and recovery approval work in phone browsers with a bottom navigation bar; an admin can confirm a recovery request with a passkey from the phone; same security rules as on desktop	P1
FR-38	Motion and feedback	The 13 approved animations behave as specified in design doc section 10 and the motion library, on phone and web; anything over 1 s can be skipped with a tap; a quicker version plays after the first 3 times; the reduced-motion setting shows the final state with a 200 ms fade; haptics paired on Android; 60 fps on a mid-range Android phone	P1

ID	Requirement	Acceptance criteria	Priority
FR-39	Admins and roles, managed only by admins	Only the super admin or an Owner can add admins, change an admin's role or remove an admin, from the Admins and roles screen; new admins are invited by email and must register a hardware security key at first sign-in; built-in roles Owner, Admin and Auditor, plus custom roles an Owner creates by choosing permissions (manage users, reset two-step sign-in, start recovery, urgent decrypt, view audit log, manage admins); the super admin can never be removed, demoted or suspended (FR-40); every change is written to the audit log and all Owners are notified	P1
FR-40	Permanent super admin	Exactly one super admin per organisation, created by the setup server command and holding every permission; it can never be deleted, demoted, suspended or locked from the console by anyone, including Owners, so the organisation can never lose access to its console; it shows a Super admin badge and a lock instead of edit or remove controls; the super admin can hand the role to another admin only by confirming with their own security key, and then becomes an Owner; if the super admin's security key is lost or stolen, a break-glass server command (run on the server, with the offline key) can reset the key or freeze the account, but never delete it; every such action is logged and all Owners are notified	P1

5. Key user stories and flows

- As a user, I can add a bank entry with a login password and a separate transaction PIN, so all credentials for one account live together.

- As a user, I can reveal a password briefly and have it hide itself, so shoulder-surfers don't see it.
- As a user, I can put entries in nested groups and tag them with labels, so I can find "Work → AWS" or everything labelled "2FA".
- As a user, I can copy a password without revealing it, so it never appears on screen.
- As a reviewer, I can log in to a demo vault and understand the security model in 10 minutes.

Add entry flow

```

flowchart LR
    A[Tap + Add] --> B[Pick template]
    B --> C[Fill name, username]
    C --> D{Password}
    D -->|Generate| E[Generator sheet]
    D -->|Type| F[Strength + reuse check]
    E --> F
    F --> G[Add group, labels,<br/>extra fields]
    G --> H[Encrypt on device]
    H --> I[Save + sync]
  
```

Encryption happens before the save request, so the API only ever receives ciphertext.

Reveal password flow

```

stateDiagram-v2
    [*] --> Masked
    Masked --> ReAuth: tap eye (protected group)
    Masked --> Revealed: tap eye
    ReAuth --> Revealed: success
    ReAuth --> Masked: cancel/fail
    Revealed --> Masked: 20 s / tap eye / app background
  
```

A revealed field always returns to masked on its own; the user never has to remember to hide it.

6. Non-functional requirements

Security requirements are release blockers; the rest are targets.

Area	Requirement
Encryption	Argon2id (64 MB, 3 iterations) derives the master key; XChaCha20-Poly1305 encrypts each item; all via libsodium on both platforms
Zero knowledge	Server stores only ciphertext, nonces, IDs, timestamps; group names and labels are encrypted too. Exceptions: users who opt in to emergency recovery (FR-28), and every user when escrow mode is on (FR-30); the product only claims zero knowledge when escrow mode is off
Auth	Server stores a hash of a separate auth key, never the master key; JWT access (15 min) + rotating refresh token (30 days); rate limit 5 failed logins / 15 min
Transport	HTTPS only, HSTS, strict CSP on web, certificate pinning on Android (P1)
Device	FLAG_SECURE on Android; keys only in memory on web; Keystore-wrapped key on Android; wipe memory on lock
Performance	Cold start to unlock screen < 2 s; search results < 100 ms for 1,000 entries; API p95 < 300 ms
Reliability	Offline read access on Android; no data loss on sync conflicts (both versions kept)
Accessibility	WCAG 2.2 AA: contrast $\geq 4.5:1$, 44 px touch targets, screen-reader labels on every icon button
Privacy	No analytics on vault content; error logs never include item data
Quality	$\geq 90\%$ unit test coverage on the crypto package; e2e tests for register, add, reveal, sync

7. Platforms and tech constraints

One Expo codebase builds both clients; about 85–90% of UI and logic is shared, with platform files (`.native.tsx` / `.web.tsx`) for storage, crypto bindings, biometrics and autofill.

Layer	Choice
Monorepo	pnpm workspaces + Turborepo: apps/client , apps/api , packages/crypto , packages/types
Client (web + APK)	Expo SDK, Expo Router, React Native Web, TypeScript, NativeWind, TanStack Query, Zustand
Android minimum	Android 9 (API 28)
Web browsers	Latest 2 versions of Chrome, Edge, Firefox, Safari
Backend	NestJS, Prisma, Zod-shared DTOs, REST
Database	PostgreSQL 16
Hosting (initial)	Web on Vercel, API on Render or Fly.io, Postgres on Neon; later Docker Compose on a VPS
CI/CD	GitHub Actions: lint, test, build web, EAS build APK as release artifact

8. Success metrics

Success means the project is secure, usable daily, and convincing to a reviewer.

Metric	Target
Time to add a login entry	≤ 20 s from tap to saved
Time to find and copy a password	≤ 5 s
Plaintext secrets in DB, logs or network traces	0 (verified by an automated test that scans API payloads)
Crypto package test coverage	≥ 90%
Lighthouse (web) performance and accessibility	≥ 90 each
Personal daily use	Author uses Rahasya as primary manager for 30 days
Portfolio	Live demo, APK download, README with architecture diagram and threat model

9. Milestones

The build runs in seven two-week sprints, detailed in the [Rahasya build plan](#); dates assume a 5 October 2026 start and a small team (see open questions).

Sprint	Dates	Milestone	Exit criteria
S0	5 to 16 Oct 2026	Designs and repo setup	Design complete: phone screens S1 to S11, desktop web in three themes, admin console on phone and web, 13 approved animations (design doc sections 10 to 12, motion library); monorepo, CI and preview deploys green
S1	19 to 30 Oct	Crypto core and auth	Register, sign in, unlock and lock end to end; crypto test vectors identical on Android and web
S2	2 to 13 Nov	Vault API and sync	Items sync between two devices; offline edits merge; older versions kept in history
S3	16 to 27 Nov	Phone screens (internal alpha)	All 11 phone screens working on real data
S4	30 Nov to 11 Dec	Desktop web and motion	Three-pane web layout and shortcuts; all 13 animations match the motion library
S5	14 to 25 Dec	Admin console and recovery	Admin console on web and phone; a full recovery rehearsed end to end
S6	28 Dec to 8 Jan 2027	Security review and public beta	Outside review closed; APK and web beta live
After beta	2027	Phase 2	Breach checks (HIBP), import and export (FR-21), offline mode
Stretch	2027	Autofill	Android Autofill Service (FR-23)

10. Risks, assumptions and open questions

Risk	Impact	Mitigation
Crypto implemented wrongly	Vault readable by attacker	Use libsodium high-level APIs only; test vectors; external code review before release
Forgotten master password	Permanent data loss	Recovery kit at signup; clear warning; optional encrypted recovery key
Argon2id slow on low-end Android	Unlock > 3 s	Benchmark on a budget device; tune memory cost with a floor of 32 MB
React Native Web layout feels "mobile" on desktop	Weak web UX	Responsive 3-pane layout above 1024 px; keyboard shortcuts
Autofill Service needs native Kotlin	Scope creep	Keep as stretch; isolate in an Expo config plugin
Escrow key or admin account compromised (Option C)	Every vault readable at once	Escrow private key encrypted by KMS, never in env or code; decrypt only through the audited endpoint; hardware-key admin login; alert on every decrypt; yearly key rotation; escrow mode off on the public demo

Assumptions

- One person per account, signing in on several devices (phone and web) at the same time; no shared vaults in v1.
- Free-tier hosting is required, as this is a personal project.

Open questions

- ☐ Project start date and team size? The build plan assumes 5 October 2026 with 2 app engineers and 1 backend engineer
- ☒ ~~Product name: decided, Rahasya~~
- ☐ Should the demo account be read-only or reset nightly?
- ☐ Offer self-hosting docs in MVP or Phase 2?